

PO03 – Modelo Operacional de la Autoridad Certificadora (AC)

ID Documento: GOYA-PO03-001 **Version:** 1.0 **Fecha:** 2026-09-01 **Estado:** Borrador **Autor:** Oficial de Seguridad **Aprobado por:** Pendiente – Gerencia General **Clasificacion:** Confidencial **Proximo revision:** 2027-03-01

Version	Fecha	Autor	Cambios
1.0	2026-09-01	Oficial de Seguridad	Documento inicial

1. Control del Documento

1.1 Responsabilidad del documento

Funcion	Nombre	Cargo
Elaboracion	Oficial de Seguridad	Oficial de Seguridad de la Informacion
Revision tecnica	Arquitecto de Sistema	Arquitecto PKI / Criptografico
Revision operativa	Administrador CA	Administrador de la Autoridad Certificadora
Aprobacion	Pendiente	Gerente General

1.2 Distribucion

Este documento se clasifica como **Confidencial** y se distribuye al Oficial de Seguridad, Gerencia General, Administrador CA, Administrador RA, Arquitecto PKI, Custodios de Fragmentos M-of-N, Equipo de Operaciones y Auditoria Interna. Cada receptor debe registrar acuse de recibo.

1.3 Dependencias

Documento	Relacion
PS01 – Plan de Gestion de Riesgos y Amenazas	Riesgos AC-01 a AC-05 determinan los controles operativos de la CA
PS02 – Politica de Seguridad	Politica marco de seguridad aplicable a la operacion CA
PS03 – Plan de Continuidad de Negocio	Recuperacion ante compromiso de CA o desastre en infraestructura
PS04 – Plan del SGSI	Seccion 9: inventario y ciclo de vida de claves gestionadas por la CA
PS05 – Plan de Auto-evaluacion	Metricas e indicadores de desempeno operacional de la CA
PS06 – Plan de Administracion de Llaves	Generacion, almacenamiento y destruccion de claves CA
PS07 – Plan de Gestion de Incidentes	Respuesta ante incidentes que afecten la operacion CA
CPS (Declaracion de Practicas de Certificacion)	Practicas de emision, revocacion y renovacion

2. Resumen Ejecutivo

Goya Ledger SpA opera como Prestador de Servicios de Certificacion (PSC) bajo la Ley 19.799 y DS 181/2002, buscando acreditacion conforme a EA-103 v2.1 y Decreto 24/2019.

La plataforma se implementa como un nodo blockchain en Rust (Actix-Web 4) con consenso HotStuff BFT de 4 nodos, almacenamiento en RocksDB y una PKI de dos niveles (CA raiz offline, CA intermedia operacional). La capa criptografica reside en `crates/pqc_crypto_module/`, modulo FIPS-orientado que encapsula ML-DSA-65 (FIPS 204), Ed25519 (FIPS 186-5) y ES256.

Servicios prestados: emision de certificados X.509 FEA/FES, revocacion con publicacion CRL (RFC 5280) y OCSP (RFC 6960), sellado de tiempo RFC 3161 y registro de identidad via RA. Todas las funciones criticas de PKI se operan sin externalizacion; unicamente se externalizan IaaS (Fly.io) y sincronizacion NTP.

3. Servicios Prestados

3.1 Autoridad Certificadora (CA)

Componente	Funcion	Implementacion
CA raiz	Firma del certificado CA	Offline, ceremonia M-of-N (<code>src/pki_ceremony.rs</code>)

Componente	Funcion	Implementacion
CA intermedia	intermedia y CRL raiz	
	Emision de certificados de suscriptores, TSA, OCSP, TLS	Online, <code>src/pki.rs</code> (<code>NodeCaConfig</code>), <code>src/pki_chain.rs</code>

Politica de emision en `src/pki_policy.rs` (restricciones de perfil, extensiones X.509, OIDs, periodos de validez). Ciclo de vida en `src/pki_lifecycle.rs` (emision, suspension, reactivacion, revocacion, expiracion).

3.2 Autoridad de Registro (RA)

La RA (`src/identity/ra.rs`) valida identidad antes de la emision. Estados: Pending, Verified, Rejected. Metodos: InPerson y VideoConference (nivel alto, FEA), RemoteAutomated (nivel basico, FES).

3.3 Sellado de tiempo (TSA)

La TSA (`src/tsa/mod.rs`) emite sellos RFC 3161 con clave ML-DSA-65. Sella: emision de certificados, revocaciones, generacion de CRL y eventos de auditoria criticos.

3.4 Estado de certificados

El respondedor OCSP (`src/msp/ocsp.rs`, RFC 6960) proporciona estado en tiempo real. La CRL (`src/msp/crl_rfc5280.rs`, RFC 5280) se publica en cada revocacion o segun intervalo periodico.

3.5 Interdependencias

La CA depende de la RA para validacion de identidad previa a emision. La TSA sella temporalmente las operaciones de la CA. CRL/OCSP depende de la CA para la lista de revocaciones. Todas las operaciones se registran en el log de auditoria encadenado por hash (`src/audit.rs`).

4. Ubicaciones Operativas

Componente	Ubicacion	Detalles
Nodos BFT (4 instancias) + CA intermedia + OCSP + CRL	Fly.io, region IAD (Ashburn, Virginia)	API puerto 8080, P2P puerto 8081, RocksDB
CA raiz (ceremonia)	Instalacion segura offline	Air-gapped, HSM FIPS 140-2 L3, acceso biometrico, videgrabacion

Componente	Ubicacion	Detalles
Sitio DR	Region geografica separada de IAD	Replicas BFT sincronizadas, RTO 4h, RPO 1h (PS03)

5. Tipos de Certificados Emitidos

5.1 Catalogo

Tipo	Algoritmo	Clave pub.	Firma	Validez	OID politica
CA raiz	ML-DSA-65 (FIPS 204)	1952 B	3309 B	10 anos	1.3.6.1.4.1.XXXXXX.0.0
CA intermedia	ML-DSA-65 (FIPS 204)	1952 B	3309 B	5 anos	1.3.6.1.4.1.XXXXXX.0.1
FEA suscriptor	ML-DSA-65 (FIPS 204)	1952 B	3309 B	3 anos	1.3.6.1.4.1.XXXXXX.1.1
FES suscriptor	Ed25519 (FIPS 186-5)	32 B	64 B	2 anos	1.3.6.1.4.1.XXXXXX.1.2
TLS nodo	ECDSA P-256 (FIPS 186-5)	65 B	64 B	1 ano	1.3.6.1.4.1.XXXXXX.2.1
TSA firma	ML-DSA-65 (FIPS 204)	1952 B	3309 B	3 anos	1.3.6.1.4.1.XXXXXX.3.1
OCSP respondedor	ML-DSA-65 (FIPS 204)	1952 B	3309 B	90 dias	1.3.6.1.4.1.XXXXXX.4.1

OIDs definitivos se asignaran al obtener el arco registrado ante IANA/ISO. Los certificados FEA se emiten mediante `POST /api/v1/certificates/fea`.

5.2 Extensiones X.509v3

Extension	FEA	FES	TLS	TSA	OCSP
Key Usage	digitalSignature, nonRepudiation	digitalSignature	digitalSignature, keyEncipherment	digitalSignature	digitalSignature
Extended Key Usage	emailProtection	emailProtection	serverAuth, clientAuth	timeStamping	OCSPSigning
	Si	Si	Si	Si	No

Extension	FEA	FES	TLS	TSA	OCSP
CRL Distribution Points					
Authority Info Access	OCSP URI	OCSP URI	OCSP URI	OCSP URI	No
Subject Alt Name	DID:goya: {pubkey_hex}	DID:goya: {pubkey_hex}	DNS nodo	N/A	N/A

6. Servicios Externalizados

Servicio	Proveedor	Controles
IaaS	Fly.io	SLA 99.99%, cifrado en transito/reposo, region IAD, SOC 2
NTP	Proveedor NTP	Multiples fuentes, validacion de desviacion

Funciones no externalizadas: generacion de claves, emision/revocacion de certificados, CRL, OCSP, TSA, verificacion RA, administracion HSM, auditoria. Proveedores se evaluan anualmente conforme a PS01 (certificaciones, SLA, riesgos de dependencia, clausulas de proteccion de datos).

7. Proteccion de Activos

7.1 Proteccion de claves privadas

Activo	Proteccion
CA raiz	HSM FIPS 140-2 L3, offline air-gapped, M-of-N 3-de-5
CA intermedia	HSM FIPS 140-2 L3, PKCS#11 (src/identity/hsm.rs)
TSA / OCSP	HSM FIPS 140-2 L3, OCSP rotacion 90 dias
TLS nodos	Volumen persistente cifrado Fly.io
Suscriptores	Dispositivo del suscriptor, generacion local

7.2 Ceremonia M-of-N

Protocolo definido en `src/pki_ceremony.rs`:

Fase de preparacion:

1. Oficial de Seguridad emite convocatoria formal con 72 horas de anticipacion.
2. Verificacion de identidad de cada custodio al ingreso a la sala de ceremonia.
3. Inspeccion de precintos de seguridad del HSM.

4. Activacion del sistema de videograbacion.
5. Verificacion del ambiente air-gapped (sin conectividad de red).

Fase de generacion:

1. Custodios activan el HSM con quorum 3-de-5.
2. HSM genera par de claves ML-DSA-65 internamente.
3. Se exporta unicamente la clave publica.
4. Se genera y firma el certificado auto-firmado de CA raiz.
5. Se verifica la firma del certificado generado.

Fase de distribucion:

1. HSM genera secreto de activacion.
2. Secreto se divide en 5 fragmentos (esquema de umbral 3-de-5).
3. Cada fragmento se almacena en medio seguro individual.
4. Cada custodio recibe su fragmento en sobre sellado y numerado.

Fase de cierre:

1. HSM se sella con precinto numerado y se almacena en caja fuerte con acceso dual.
2. Se detiene la videograbacion y se redacta acta notarial.
3. Se distribuyen copias del acta a cada custodio y al Oficial de Seguridad.

7.3 Respaldos cifrados

Elemento	Frecuencia	Cifrado	Retencion
RocksDB + log auditoria	Diario	AES-256-GCM	10 anos
Configuracion CA	Cada cambio	AES-256-GCM	Vigencia certificado CA
Fragmentos M-of-N	Generacion	Individual por custodio	Vigencia CA raiz

Inventario de activos (HSM, nodos, fragmentos, certificados CA, licencias) revisado trimestralmente.

8. Componentes del Sistema

8.1 Interfaces CA-RA

Endpoint	Metodo	Funcion
/api/v1/identity/verify	POST	Solicitar verificacion de identidad
/api/v1/identity/status/{id}	GET	Consultar estado (Pending/Verified/Rejected)

Endpoint	Metodo	Funcion
/api/v1/certificates/fea	POST	Emitir certificado FEA (requiere Verified)

CA consulta RA antes de emitir; si estado es Pending o Rejected, rechaza con error especifico. Comunicacion protegida por mTLS con certificados de CA intermedia, autorizacion via enforce_acl.

8.2 Elementos de seguridad

Control	Implementacion
TLS 1.3	Todas las comunicaciones, cipher suites AES-256-GCM y CHACHA20
mTLS	Nodos BFT (P2P puerto 8081)
HSM PKCS#11	Claves CA, TSA, OCSP (src/identity/hsm.rs)
Cifrado en reposo	Volumenes Fly.io
Integridad	Consenso BFT, log encadenado por hash SHA-256 (src/audit.rs)
Zeroizacion	Material criptografico en memoria al finalizar uso

8.3 Roles y separacion de funciones

Rol	Responsabilidades
Administrador CA	Configuracion CA, emision certificados, gestion perfiles
Administrador RA	Verificacion identidad, aprobacion/rechazo solicitudes
Oficial de Seguridad	Políticas, auditoria de accesos, gestion incidentes
Auditor	Revision logs, integridad, reportes de cumplimiento (solo lectura)
Custodio M-of-N	Custodia fragmento CA raiz, participacion en ceremonias (quorum 3-de-5)

Incompatibilidades: CA Admin + RA Admin, CA Admin + Oficial de Seguridad, CA Admin + Auditor, Custodio + CA Admin. Control via ACL_MODE=strict en produccion.

8.4 Directorio y repositorio

Recurso	Protocolo	Disponibilidad
Certificados CA raiz/intermedia	HTTPS publico	24/7
CRL	HTTPS (RFC 5280)	Actualizado en cada revocacion, minimo cada 24h

Recurso	Protocolo	Disponibilidad
OCSF	HTTP/HTTPS (RFC 6960)	24/7, latencia < 500ms

Almacenamiento en RocksDB con claves zero-padded 12 digitos: certificados {serie:012}, CRL `crl:{secuencia:012}`, auditoria `audit:{timestamp:012}`, revocaciones `revoke:{serie:012}`.

8.5 Auditoria y respaldo

8.5.1 Log de auditoria encadenado por hash

El sistema (`src/audit.rs`) registra cada evento con los siguientes campos:

Campo	Descripcion
Timestamp	Marca temporal UTC de la operacion
Event type	Tipo (emision, revocacion, acceso HSM, administracion, seguridad, ceremonia)
Actor	Identidad del operador o sistema
Resource	Recurso afectado (certificado, clave, configuracion)
Previous hash	Hash SHA-256 de la entrada anterior
Entry hash	Hash SHA-256 de la entrada actual

8.5.2 Verificacion de integridad

Procedimiento automatizado diario:

1. Lee la cadena completa de entradas desde RocksDB.
2. Recalcula el hash SHA-256 de cada entrada.
3. Verifica que `previous_hash` coincida con el hash de la entrada anterior.
4. Compara el ultimo hash con el almacenado en nodo independiente.
5. Genera alerta al Oficial de Seguridad si detecta discrepancia.

8.5.3 Retencion

Tipo de registro	Retencion	Base legal
Log de auditoria	10 anos	DS 181/2002, Art. 14
Certificados emitidos	10 anos post-expiracion	DS 181/2002, Art. 14
CRL historicas	10 anos	ETSI TS 102 042 seccion 7.4.8
Registros de ceremonia	Vigencia CA raiz + 5 anos	Politica interna

8.6 Bases de datos

RocksDB seleccionado via `STORAGE_BACKEND=rocksdb`. Consenso BFT (4 nodos, $2f+1 = 3$) garantiza que toda escritura sea acordada por mayoría, proporcionando tolerancia a fallas bizantinas e inmutabilidad.

8.7 Privacidad

Certificados contienen datos minimos: Subject CN (nombre/identificador), Subject SAN (`did:goya:{pubkey_hex[...16]}`), Serial Number. Excluidos: documento identidad, direccion, telefono, correo personal, biometricos. Datos RA retenidos 10 anos post-emision; biometricos FEA eliminados tras verificacion. Alineacion con Ley 19.628, principios RGPD y DS 181/2002.

8.8 Capacitacion del personal

Tipo	Frecuencia	Audiencia
Induccion PKI	Al ingreso	Personal operaciones CA
Ceremonia de claves	Previo a ceremonia	Custodios M-of-N
Respuesta a incidentes	Anual	Personal operaciones CA
Actualizacion normativa	Anual	CA Admin, Oficial de Seguridad
Seguridad de la informacion	Anual	Todo el personal

Cada actividad se registra con fecha, asistentes, contenido, evaluacion y fecha de recertificacion.

9. Proceso de Certificacion

9.1 Emision FEA

1. Solicitante genera par ML-DSA-65 localmente y envia CSR con documentacion via `POST /api/v1/identity/verify`.
2. RA Admin verifica identidad (InPerson/VideoConference); RA actualiza `ProofingStatus` a `Verified` o `Rejected`.
3. Solicitante solicita certificado via `POST /api/v1/certificates/fea`.
4. CA verifica estado RA = `Verified`, genera certificado X.509v3 (`src/pki_chain.rs`, `src/pki_policy.rs`), firma con CA intermedia via HSM.
5. TSA sella la emision (`src/tsa/mod.rs`), certificado se publica en RocksDB, evento se registra en `src/audit.rs`.
6. CA entrega certificado en `ApiResponse<T>` con trace ID.

Emision FES: par Ed25519, verificacion RemoteAutomated, flujo simplificado.

9.2 Revocacion

1. Suscriptor o RA solicita revocacion con motivo.
2. CA Admin verifica autoridad del solicitante para revocar el certificado.
3. CA cambia estado del certificado a revocado en `src/pki_lifecycle.rs`.
4. CRL actualizada incluyendo certificado revocado (`src/msp/crl_rfc5280.rs`).
5. OCSF actualiza estado del certificado (`src/msp/ocsp.rs`).
6. TSA sella temporalmente la revocacion.
7. Evento registrado en log de auditoria con motivo.

Motivos de revocacion soportados (RFC 5280 CRLReason):

Codigo	Motivo
0	unspecified
1	keyCompromise
3	affiliationChanged
4	superseded
5	cessationOfOperation

9.3 Renovacion y suspension

Renovacion requiere certificado vigente o dentro de 30 dias post-expiracion, verificacion RA vigente (max 3 anos FEA) y nuevo par de claves. Suspension: maximo 30 dias, OCSF reporta “unknown”, reactivacion requiere verificacion de identidad, revocacion automatica si no se reactiva.

10. Plan de Auditoria

Tipo	Frecuencia	Alcance	Responsable
Interna operativa	Trimestral	CA, RA, TSA, OCSF, procedimientos	Oficial de Seguridad
Interna seguridad	Semestral	Controles PS02, HSM, segregacion	Auditor Interno
Externa cumplimiento	Anual	EA-103, DS 181/2002, ETSI TS 102 042	Auditor externo
Integridad log	Diaria (automatizada)	Cadena hash auditoria	Sistema

10.2 Procedimiento de auditoria interna

1. Planificacion: definicion de alcance, criterios y calendario.
2. Ejecucion: revision de registros, entrevistas, verificacion de controles.
3. Hallazgos: clasificacion por severidad (critico, mayor, menor, observacion).

4. Informe: documentacion con evidencia y recomendaciones.
5. Plan de accion: responsable, plazo y verificacion de cierre por hallazgo.
6. Seguimiento: verificacion de implementacion de acciones correctivas.

10.3 Indicadores de desempeno

Indicador	Meta	Medicion
Disponibilidad OSCP	$\geq 99.9\%$	Monitoreo continuo
Latencia OSCP	$< 500\text{ms P95}$	Metricas de latencia
Publicacion CRL post-revocacion	< 15 minutos	Log de auditoria
Hallazgos criticos no resueltos	0	Informe de auditoria
Capacitacion completada	100% personal	Registro de capacitacion

11. Seguridad Fisica

11.1 Centro de datos (Fly.io IAD)

Control	Descripcion
Seguridad perimetral	Control de acceso fisico del proveedor (SOC 2 Type II)
Vigilancia	CCTV 24/7, registro de accesos
Proteccion ambiental	Sistemas contra incendios, control de temperatura y humedad
Redundancia electrica	UPS y generadores diesel
Validacion	Goya Ledger verifica certificaciones del proveedor anualmente

11.2 Instalacion de ceremonia CA raiz

Control	Descripcion
Acceso	Biometrico + tarjeta + PIN
Conectividad	Air-gapped, sin conexion de red
HSM	Caja fuerte con acceso dual (dos llaves fisicas, diferentes custodios)
Registro	Videograbacion, bitacora fisica de acceso
Precintos	Numerados, verificados antes y despues de cada ceremonia

11.3 Almacenamiento de fragmentos M-of-N

Cada fragmento se almacena en caja de seguridad bancaria individual del custodio asignado. Sobre sellado con numero de serie y firma del Oficial de Seguridad. Verificacion semestral de integridad del sellado.

12. Seguridad del Personal

Rol	Verificacion
CA Admin / Oficial Seguridad	Antecedentes penales, referencias 5 anos, verificacion identidad
RA Admin / Custodio M-of-N	Antecedentes penales, referencias 3 anos
Auditor	Independencia, certificaciones, antecedentes penales

Todo personal con acceso a sistemas PKI firma:

- Acuerdo de confidencialidad (NDA) que cubre claves, ceremonias, datos de suscriptores y vulnerabilidades.
- Declaracion de conflicto de intereses.
- Aceptacion de la politica de seguridad (PS02).

En produccion (RUST_BC_ENV=production) el sistema exige ACL_MODE=strict.

12.3 Procedimiento de desvinculacion

1. Revocacion inmediata de credenciales de acceso.
 2. Recuperacion de fragmentos M-of-N (si aplica) con regeneracion para nuevo custodio.
 3. Revision de accesos realizados en los ultimos 90 dias.
 4. Recordatorio formal de obligaciones de confidencialidad post-empleo.
 5. Registro del evento en log de auditoria.
-

13. Seguridad del Modulo Criptografico

13.1 Requisitos HSM

FIPS 140-2 Nivel 3 (migracion FIPS 140-3 planificada), interfaz PKCS#11 v2.40 (src/identity/hsm.rs), DRBG certificado NIST SP 800-90A, proteccion y zeroizacion ante manipulacion fisica.

13.2 Protocolo de ceremonia

Definido en `src/pki_ceremony.rs`. Fases: preparacion (convocatoria 72h, verificacion identidad, inspeccion precintos, videgrabacion, verificacion air-gap), generacion (quorum 3-de-5 activa HSM, generacion ML-DSA-65, exportacion clave publica, certificado auto-firmado), distribucion (secreto dividido en 5 fragmentos, sobres sellados numerados), cierre (precinto HSM, caja fuerte dual, acta notarial).

13.3 Agilidad criptografica

Algoritmo	Estandar	Uso	Estado
ML-DSA-65	FIPS 204	FEA, CA, TSA, OCSP	Primario (post-cuantico)
Ed25519	FIPS 186-5	FES, consenso BFT	Activo (clasico)
ES256	FIPS 186-5	OID4VCI, TLS	Activo (clasico)
SLH-DSA-128s	FIPS 205	Respaldo post-cuantico	Disponible

Firmas como `Vecu8` (no arrays fijos), `SigningAlgorithm` con `#[serde(default)]` en cada estructura firmada, serializacion hex via `vec_hex`. Frontera criptografica verificada por cargo `test --test crypto_boundary`: importaciones directas de primitivas en `src/` prohibidas, todo canalizado via `crates/pqc_crypto_module/`.

14. Referencias

14.1 Normativa nacional

Norma	Descripcion
Ley 19.799	Documentos electronicos, firma electronica y PSC
DS 181/2002	Reglamento de la Ley 19.799
Decreto 24/2019	Norma tecnica para PSC acreditados
Ley 19.628	Proteccion de datos personales
EA-103 v2.1	Guia de Acreditacion de PSC

14.2 Normativa internacional y estandares

Norma	Descripcion
Reglamento (UE) 910/2014 (eIDAS)	Servicios de confianza e identificacion electronica
ETSI TS 102 042	Requisitos de politica para CA
RFC 5280	X.509 PKI: perfil de certificado y CRL

Norma	Descripcion
RFC 6960	Online Certificate Status Protocol (OCSP)
RFC 3161	Protocolo de sellado de tiempo
FIPS 140-2 / 140-3	Modulos criptograficos
FIPS 186-5	Firma digital (Ed25519, ECDSA)
FIPS 204	ML-DSA
FIPS 205	SLH-DSA
NIST SP 800-57 Pt.1 Rev.5	Gestion de claves
NIST SP 800-88 Rev.1	Sanitizacion de medios
NIST SP 800-90A	Generacion de numeros aleatorios

14.3 Documentos internos

Documento	Descripcion
CPS	Practicas operativas de la CA
PS01	Gestion de riesgos y amenazas
PS02	Politica de seguridad
PS03	Continuidad de negocio
PS04	Sistema de gestion de seguridad de la informacion
PS05	Auto-evaluacion
PS06	Administracion de llaves criptograficas
PS07	Gestion de incidentes